

VoiceSecure Wallet

Production-Grade Fintech Platform · Agent Build Plan · v2.0 Amended

Document Type: Engineering Execution Plan (Amended)

Audience: Autonomous Build Agent / Senior Engineer

Version: 2.0 · June 2026 · Supersedes v1.0

Classification: Confidential — Internal Only

Build Duration: 20 Weeks · 7 Phases

Services: 10 Microservices · Java + Python

Key Amendments: Signed ledger · Voice fallback flows · Device binding · Admin repair API · Compliance service

Table of Contents

1. Problem Statement & Business Context
2. Platform Impact Analysis
3. Critical Non-Negotiables \ AMENDED
4. Architecture Decision Register ★ NEW ENTRIES
5. Service Catalogue ★ 3 NEW SERVICES
6. Data Architecture \ SIGNED LEDGER
7. Event Backbone & Kafka Topology
8. Payment Saga State Machine \ +3 STATES
9. Security Architecture \ DEVICE BINDING
10. Observability & SLOs
11. Implementation Phases ★ 7 PHASES / 20 WEEKS
12. Testing Strategy ★ +3 SUITES
13. Infrastructure & Deployment
14. Critical Invariants
15. Launch Criteria ★ +5 GATES

1. Problem Statement & Business Context

The Problem

Digital payment fraud in South Africa cost the financial sector an estimated R3.2 billion in 2024 (SABRIC). Existing wallet platforms authenticate users at login only — once a session is established, any payment executes without re-verification. A stolen device or hijacked session gives an attacker unrestricted access to funds. Legacy systems also lack per-transaction biometric verification, real-time fraud scoring, and immutable audit trails, making regulatory compliance (SARB, FSCA, POPIA, FICA) exceptionally difficult to prove.

THE CORE PROBLEM

Current fintech platforms lack per-transaction biometric verification. Authentication happens once at session start. Payment authorisation relies solely on session validity — not proof that the account holder is present at each transaction. Fraud, SIM-swap attacks, and device theft exploit this gap directly. Regulatory bodies (SARB, FSCA) have no verifiable audit trail to inspect.

Our Vision

VoiceSecure Wallet builds a financially correct, fraud-resistant, and regulatory-ready payment platform. Voice biometrics is a primary but fallible factor — backed by step-up authentication (OTP, PIN, device cryptography). Every payment is scored by a hybrid ML/rules fraud engine, and every cent is tracked in an append-only, double-entry signed ledger that mathematically proves its own correctness at all times.

SUCCESS DEFINITION (v2.0)

Financial Correctness: $\text{SUM}(\text{signed_amount}) = 0$ at all times. Reconciliation every 6 hours. · Payment Integrity: Idempotent payments, explicit compensation, human repair for `COMPENSATION_FAILED`. · User Availability: 99.5% payment success. Voice failure triggers OTP/PIN fallback — never a hard block. · Compliance Readiness: SARB/FSCA audit trails, PEP/AML monitoring, STR workflow. · Operational Maturity: Admin dashboards, customer support tools, voice re-enrolment workflows.

THE CUSTOMER PRINCIPLE (Added v2.0)

The ledger is the system. Everything else is scaffolding. Keep the signed reconciliation test green and you know the system is honest. But: the customer is the reason. If voice locks out a legitimate user, we have failed — regardless of ledger correctness.

2. Platform Impact Analysis

Impact on Existing Platform Components

Component	Impact	Action Required	Risk	v2 Change
API Gateway	JWT RS256, per-user rate limiting, device signature header validation	Reconfigure JWT validator. Add X-Device-Signature forwarding rule.	Medium	Amended
User Auth	Per-transaction re-verification layer. Device keypair binding added.	JWKS endpoint. Token family revocation. Device public key registration.	Medium	Amended
Payment Processing	Replaced by saga with voice + fallback states.	Blue/green cutover. Drain in-flight payments before switching.	High	Amended
Database Layer	Mutable balances → signed append-only ledger.	Migration script. signed_amount reconciliation before and after.	High	Amended
Notification System	Synchronous triggers → Kafka event consumers.	Refactor to consume payment.* events.	Low	Unchanged
Monitoring	Metrics replaced by four golden signals + SLO dashboards.	CloudWatch dashboards rebuilt. Alert rules migrated.	Low	Unchanged
Mobile Client	Voice capture SDK + fallback OTP/PIN UI on payment screen.	Voice capture component. Fallback payment UX. Device keypair generation.	Medium	Amended

Migration Strategy (v2.0)

Step 1: Run new signed ledger in shadow mode. Reconcile SUM(signed_amount)=0 after 48 hours of mirrored writes.

Step 2: Migrate historical balances. All debits stored as negative, credits as positive. Reconcile before and after.

Step 3: Cut payment flow to saga. Drain in-flight payments. Keep legacy flow as fallback for 72 hours.

Step 4: Enforce voice verification in warning-only mode. Verify OTP fallback works. Promote to enforcement after 48 hours clean.

Step 5: Enable device binding. Require X-Device-Signature on critical endpoints. Existing sessions grace period 7 days.

Step 6: Decommission legacy balance tables after 30 days clean operation.

ROLLBACK POSITION

Each step independently reversible. Saga switchable via feature flag. Voice enforcement toggled at fraud-service threshold. Device binding can be disabled per user for re-enrolment. Signed ledger migration is the only irreversible step — hence double reconciliation.

3. Critical Non-Negotiables (✍ Amended v2.0)

VOICE IS A FACTOR, NOT THE SOLE AUTH (Amended)

Voice must have fallback (OTP, device PIN, or hardware key) with explicit state-machine paths for VOICE_FAILED_FALLBACK. A voice service outage must never block a legitimate payment. High-value transactions (>R5,000) require voice plus fallback factor.

SIGNED LEDGER INVARIANT (Amended)

All ledger entries store signed_amount (positive for credits, negative for debits). SUM(signed_amount) = 0 is the hard invariant — enforced at application level on every write and validated every 6 hours. This replaces the original unsigned CHECK constraint approach.

DEFENSE IN DEPTH FOR AUTH (Amended)

JWT validation at API Gateway AND inside critical services (payment initiation, balance reads). Device cryptographic identity (Android Keystore / Apple Secure Enclave) bound to session. No single auth layer failure compromises the system.

MANUAL REPAIR IS FIRST-CLASS (Amended)

COMPENSATION_FAILED pages SRE immediately and unlocks a secure admin API (POST /repair — requires IAM + MFA) to issue corrective ledger entries with full audit logging and mandatory justification payload. Repair workflow must be tested before go-live.

NO SHARED LOGICAL DATABASES (Amended)

While RDS clusters may be shared for cost, each service has its own logical database (not just schema) with credentials scoped accordingly. Cross-service SQL joins are forbidden — event-driven integration only.

LEDGER IS APPEND-ONLY

No UPDATE or DELETE on ledger_entries, ever. Not in migrations, not in hotfixes. Any correction must be a new compensating entry via the repair API. This is what makes the audit trail trustworthy and regulatory-compliant.

COMPENSATION_FAILED CANNOT BE SILENT

Immediate Tier 1 page. SRE team performs repair via admin API within RTO. Every repair action is logged to the Tier 1 audit trail with justification. Repair drill must be completed before launch criteria gate 13 is signed off.

4. Architecture Decision Register

Locked decisions — do not re-open without explicit instruction

Branch	Decision	Rationale
✂️ AMENDED Ledger Amounts	signed_amount BIGINT — negative debit, positive credit	SUM(signed_amount)=0 is simpler and cleaner than unsigned pair tracking. CHECK: signed_amount != 0.
✂️ AMENDED Voice Auth Model	Voice is one factor in multi-factor flow, not sole auth	Voice outage must not block payments. VOICE_FAILED_FALLBACK state routes to OTP/PIN. High-value requires both.
✂️ AMENDED Database Isolation	Shared RDS cluster, separate logical databases per service	Separate databases (not schemas) with service-scoped credentials. No cross-DB SQL joins — events only.
★ NEW Device Binding	Mobile keypair bound to identity-service; every critical request signed	Android Keystore / Apple Secure Enclave. X-Device-Signature header. fraud-service computes device_trust_score.
★ NEW Admin Repair API	POST /repair on ledger-service (IAM + MFA gated)	COMPENSATION_FAILED requires human resolution. Repair issues corrective entry with mandatory justification. Full audit log.
★ NEW Compliance Service	Dedicated compliance-service owns PEP/AML/STR	Separate regulatory regime from fraud scoring. Own audit trail. External consultant validation before launch.
★ NEW Recovery Service	Dedicated recovery-service for lost device / voice change	Re-enrolment requires ID upload + video KYC. Separate from identity-service to isolate high-risk flow.
★ NEW Support Service	Internal support-service for admin operations	Read-only views, account freeze, dispute intake, audit log browsing. IAM + internal IdP. No external access.
✂️ AMENDED Outbox Scaling Path	Polling 100ms → LISTEN/NOTIFY → Debezium CDC	Explicit ADR. Migrate when outbox rows exceed 1,000/sec. Each step is an independent ADR decision.
★ NEW Hot Account Sharding	account_balance_slots for accounts exceeding 50 TPS	Defined as future ADR. Ledger-service routes balance writes to sharded slots above threshold.
Balance Read Path	CQRS read model via Kafka, with SELECT FOR UPDATE as authority	Eventual consistency acceptable as pre-flight hint. Reservation enforces correctness at ledger write.
Concurrency Control	SELECT FOR UPDATE + signed_amount CHECK constraint	Pessimistic locking prevents overdraft. CHECK constraint is last-resort safety net.
Account Model	Multi-wallet: spending / escrow / savings	In-flight funds move spending→escrow→destination. Ledger balanced at every saga step.
✂️ AMENDED Fraud Language	Python — ML ecosystem alignment with voice-service	Rules engine and ML model share feature pipeline. fraud-service now also sets auth_policy per transaction.

 AMENDED Voice Embeddings	PostgreSQL + pgvector + liveness detection	One-to-one comparison. pgvector in ACID transactions. Liveness (passive + active challenge) added in v2.
 AMENDED Voice Degradation	Tiered by transaction value + OTP/PIN fallback paths	Voice outage → OTP for low-value, OTP+PIN for high-value. Never a hard block on legitimate user.
 AMENDED JWT Signing	RS256 + service-level re-validation on critical endpoints	Gateway validates all. Critical services re-validate signature using JWKS for defence in depth.
Kafka Schema	Avro + Schema Registry BACKWARD compatibility	Schema evolution without breaking consumers. Compatibility check is CI gate.
Partition Keys	payment_id for payment topics; account_id for ledger topics	Ordering guaranteed per payment and per account respectively.
Consumer Failure	Kafka transactions primary + idempotency safety net	Defense in depth. Transactional consumers prevent duplicates.
Orchestration	ECS Fargate — no EC2 management	Ten services, not a hundred. Kubernetes complexity unjustified. Native IAM per task.
IaC	Terraform + S3 state + DynamoDB locking	Provider-agnostic, portable. State locking prevents concurrent apply conflicts.
Deployment	Blue/green + 5% canary + auto-rollback	No big-bang deploys. Automated rollback if error rate breaches threshold during canary.

5. Service Catalogue

10 services — 3 new in v2.0 ★ = NEW ✂ = AMENDED

payment-service ✂ AMENDED (Java · Saga orchestrator)

Responsibility	Payment lifecycle, 18-state saga (15 original + 3 fallback states), idempotency keys, outbox relay. Implements degradation tiers: voice optional / required / required+step-up.
Database	payments, sagas, idempotency_keys, outbox
Communications	Calls: ledger-service, fraud-service, voice-service Consumes: fraud.scored, voice.verified/rejected/timeout/fallback_requested Publishes: all payment.* events via outbox

ledger-service ✂ AMENDED (Java · Financial core)

Responsibility	signed_amount ledger_entries (append-only). account_balances materialized projection. Exposes POST /repair (IAM + MFA) for manual compensation with mandatory justification. The only service that writes to ledger tables.
Database	ledger_entries (signed), account_balances, accounts
Communications	Internal API only — never reachable from API Gateway Publishes: ledger.entry_posted Exposes: POST /repair (admin, IAM+MFA gated)

wallet-service (Java · User-facing balances)

Responsibility	Wallet metadata, account creation, balance display via CQRS read model. Never writes to ledger directly.
Database	wallet_metadata, user_account_mappings
Communications	Consumes: ledger.entry_posted (CQRS balance read model) Never writes to ledger — not even in emergencies

fraud-service ✂ AMENDED (Python · Risk engine + auth policy)

Responsibility	Two-layer pipeline: rules engine (hard blocks) + ML scoring. Redis velocity checks. Device fingerprints. Sets auth_policy (VOICE_ONLY / VOICE_OTP / DEVICE_PIN) per transaction. Integrates PEP/AML via compliance-service.
Database	fraud_signals, device_registry, rule_configs, ml_models (S3)
Communications	Publishes: fraud.scored (includes auth_policy and voice_threshold) Calls: compliance-service (sync, sanctions/PEP check) Redis: velocity sliding windows (Lua script)

voice-service ✂ AMENDED (Python · Biometric verification)

Responsibility	Speaker embeddings (pgvector), liveness detection (passive + active challenge), audio fingerprint storage for replay detection, confidence scoring pipeline. Publishes voice.fallback_requested when confidence < threshold.
Database	embeddings (pgvector, double-encrypted), verification_sessions, audio_fingerprint_hashes

Communications	Publishes: voice.verified, voice.rejected, voice.timeout, voice.spoof_detected, voice.fallback_requested Threshold received from fraud-service per request
-----------------------	--

identity-service **AMENDED** (Java · Auth & device identity)

Responsibility	Users, credentials, JWT issuance (RS256), OAuth2 flows, refresh token families (family-wide revocation on stolen token detection). Stores device public keys. Issues device_id claim in JWT. Validates device signature on critical endpoints.
Database	users, credentials, sessions, refresh_token_families, device_public_keys
Communications	Exposes: JWKS endpoint Validates: X-Device-Signature header on critical endpoints Publishes: identity.device_registered, identity.token_family_revoked

compliance-service **NEW** (Java · Regulatory (NEW))

Responsibility	PEP lists, AML rules engine, STR (Suspicious Transaction Report) workflow. Daily sync of SARB/OFAC/FSCA lists. Publishes compliance.hit events. Own audit trail separate from fraud-service.
Database	pep_lists, sanctions_lists, aml_rules, str_cases, compliance_audit_log (7yr WORM)
Communications	Called synchronously by fraud-service Layer 1 Publishes: compliance.hit (PEP match, sanctions match, AML flag) STR workflow: integrates with SARB reporting API

recovery-service **NEW** (Java · Identity recovery (NEW))

Responsibility	Manages identity verification (ID document upload, video KYC) for lost devices or voice change events. Re-enrols voice embeddings and re-issues device certificates. High-risk flow — isolated from identity-service.
Database	recovery_requests, kyc_sessions, re_enrolment_audit_log
Communications	Calls: identity-service (device cert re-issue), voice-service (embedding update) Publishes: recovery.completed, recovery.rejected Integrates: third-party KYC provider

support-service **NEW** (Python/Java · Internal admin (NEW))

Responsibility	Internal-only API for transaction search, account freeze, manual compensation trigger, dispute intake, and audit log browsing. Secured by AWS IAM and a separate internal IdP. No external traffic ever reaches this service.
Database	dispute_cases, freeze_log, support_audit_log
Communications	Internal only — no API Gateway route Reads: ledger_entries (read-only replica), payment_sagas Calls: ledger-service POST /repair (via IAM role)

notification-service **AMENDED** (Java · Event consumer only)

Responsibility	Payment receipts, push/SMS/email dispatch, fallback OTP delivery. Event-driven only — never called synchronously.
Database	notification_log, template_registry
Communications	Consumes: payment.completed, payment.failed, payment.compensated, voice.fallback_requested (triggers OTP send) Zero inbound API calls

6. Data Architecture (✍ Signed Ledger)

Corrected Ledger Schema (v2.0)

KEY CHANGE FROM v1.0

signed_amount replaces the unsigned amount + entry_type pair. Negative values represent debits, positive values represent credits. The reconciliation invariant $\text{SUM}(\text{signed_amount}) = 0$ is simpler, more standard, and easier to verify programmatically.

ledger_entries (APPEND-ONLY — NEVER UPDATE OR DELETE)

```
CREATE TABLE ledger_entries ( id UUID PRIMARY KEY, account_id UUID NOT NULL REFERENCES accounts(id),
signed_amount BIGINT NOT NULL, -- NEGATIVE for DEBIT, POSITIVE for CREDIT currency TEXT NOT NULL
DEFAULT 'ZAR', saga_id UUID NOT NULL REFERENCES payment_sagas(id), entry_type TEXT NOT NULL, --
'DEBIT' | 'CREDIT' (descriptive only) idempotency_key UUID NOT NULL, created_at TIMESTAMPTZ NOT NULL
DEFAULT NOW(), CONSTRAINT signed_amount_nonzero CHECK (signed_amount != 0) ); -- Reconciliation
invariant: SELECT SUM(signed_amount) FROM ledger_entries = 0 -- Index: (account_id, created_at) for
balance projection queries -- Index: (saga_id) for saga-ledger consistency checks
```

account_balances (MATERIALIZED — UPDATED IN SAME TRANSACTION)

```
CREATE TABLE account_balances ( account_id UUID PRIMARY KEY REFERENCES accounts(id), balance BIGINT
NOT NULL DEFAULT 0, -- SUM(signed_amount) for this account currency TEXT NOT NULL DEFAULT 'ZAR',
version BIGINT NOT NULL DEFAULT 0, updated_at TIMESTAMPTZ NOT NULL, CONSTRAINT non_negative_balance
CHECK (balance >= 0) );
```

payment_sagas (18 STATES — 15 ORIGINAL + 3 FALLBACK)

```
CREATE TABLE payment_sagas ( id UUID PRIMARY KEY, idempotency_key UUID NOT NULL UNIQUE, user_id UUID
NOT NULL, from_account_id UUID NOT NULL, to_account_id UUID NOT NULL, amount BIGINT NOT NULL,
currency TEXT NOT NULL DEFAULT 'ZAR', state TEXT NOT NULL, -- 18 explicit states (see Section 8)
fraud_score DECIMAL(4,3), auth_policy TEXT, -- VOICE_ONLY | VOICE_OTP | DEVICE_PIN voice_threshold
DECIMAL(4,3), -- set by fraud-service per transaction fallback_method TEXT, -- OTP | PIN |
HARDWARE_KEY created_at TIMESTAMPTZ NOT NULL, updated_at TIMESTAMPTZ NOT NULL, completed_at
TIMESTAMPTZ, INDEX: (state, created_at) -- saga timeout detection );
```

Database Cluster Allocation

transactional-db	Databases: ledger_db, payment_db, wallet_db · Separate logical databases, shared RDS cluster · No cross-database SQL queries permitted · Service-scoped credentials per database
identity-db	Database: identity_db · Stores device_public_keys (v2 addition) · Most restricted network access · Separate CMK
fraud-db	Databases: fraud_db, compliance_db · Higher read volume · compliance_db includes 7-year WORM audit trail for STR/PEP/AML
voice-db	Database: voice_db · pgvector extension · audio_fingerprint_hashes table (v2 addition) · Double-layer KMS encryption · All data purged on account deletion (POPIA)
support-db (NEW)	Database: support_db · dispute_cases, freeze_log, support_audit_log · Internal only — no external network access · Read replica of ledger for search

7. Event Backbone & Kafka Topology

Universal Event Envelope

```
{ "eventId": "uuid – checked by every consumer before processing", "eventType":  
"payment.completed", "eventVersion": "1.0", "aggregateId": "payment_id", "aggregateType":  
"Payment", "occurredAt": "ISO8601", "traceId": "W3C trace context – MANDATORY, propagated through  
Kafka headers", "payload": { ... IDs only – never mutable object references ... } }
```

Topic Definitions

payments Partition: payment_id	payment.initiated · payment.fraud_check_requested · payment.fraud_approved · payment.fraud_rejected · payment.voice_requested · payment.voice_approved · payment.voice_rejected · payment.voice_timeout · payment.voice_fallback_requested · payment.voice_fallback_verified · payment.voice_fallback_failed · payment.funds_reserved · payment.funds_reservation_failed · payment.completed · payment.failed · payment.compensation_initiated · payment.compensated · payment.compensation_failed
ledger Partition: account_id	ledger.entry_posted (carries full signed_amount debit/credit pair) · ledger.reconciliation_triggered · ledger.repair_initiated · ledger.repair_completed
fraud Partition: user_id	fraud.scored (includes auth_policy + voice_threshold) · fraud.rule_triggered
voice Partition: user_id	voice.session_created · voice.verified · voice.rejected · voice.timeout · voice.spoof_detected · voice.fallback_requested (NEW)
compliance (NEW) Partition: user_id	compliance.hit (PEP match / sanctions match / AML flag) · compliance.str_filed · compliance.list_updated
identity (NEW) Partition: user_id	identity.device_registered · identity.token_family_revoked · identity.re_enrolment_completed

8. Payment Saga State Machine (🔪 +3 Fallback States)

All 18 States

State	Type	v2	Description
INITIATED	normal		Payment request received, idempotency key validated
FRAUD_CHECK_PENDING	normal		Awaiting fraud.scored + auth_policy from fraud-service
FRAUD_REJECTED	terminal		Score ≥ 0.90 or hard rule. No compensation needed.
VOICE_VERIFICATION_PENDING	normal		Awaiting voice result. 35-second saga timeout active.
VOICE_VERIFICATION_TIMEOUT	terminal		Session TTL or circuit breaker. Routes to fallback if value permits.
VOICE_REJECTED	terminal		Confidence below threshold. Routes to VOICE_FALLBACK_PENDING.
VOICE_FALLBACK_PENDING	normal	★ NEW	Awaiting OTP/PIN fallback. Triggered by voice failure or timeout.
VOICE_FALLBACK_VERIFIED	normal	★ NEW	OTP/PIN verified. Proceeds to FUNDS_RESERVING.
VOICE_FALLBACK_FAILED	terminal	★ NEW	All auth factors exhausted. No funds moved. Payment declined.
FUNDS_RESERVING	normal		SELECT FOR UPDATE on account. Signed ledger write in progress.
FUNDS_RESERVATION_FAILED	terminal		Ledger write failed. No funds moved.
FUNDS_RESERVED	normal		spending→escrow transfer committed. signed_amount balanced.
LEDGER_COMMITTING	normal		escrow→destination transfer in progress.
LEDGER_COMMIT_FAILED	terminal+compensate		Commit failed after reservation. COMPENSATION REQUIRED.
LEDGER_COMMITTED	normal		Both entries posted. Payment economically complete.
COMPLETING	normal		Publishing payment.completed via outbox.
COMPLETED	terminal		Success. Idempotency key cached with 200 response.
COMPENSATION_IN_PROGRESS	compensate		Moving escrow back to spending.
COMPENSATED	terminal		Funds returned. Idempotency key cached with 402.
COMPENSATION_FAILED	critical		IMMEDIATE SRE PAGE. Admin repair API unlocked. Manual resolution required.

Fallback Flow Rules

- VOICE_REJECTED or VOICE_TIMEOUT → transitions to VOICE_FALLBACK_PENDING (not terminal failure)
- VOICE_FALLBACK_PENDING: notification-service delivers OTP or prompts PIN. 5-minute TTL.
- auth_policy from fraud-service determines which fallback methods are permitted for this transaction
- High-value (>R5,000): auth_policy = VOICE_OTP — both voice AND fallback required. Voice cannot be skipped.

- VOICE_FALLBACK_FAILED is terminal with zero funds moved — no compensation needed
- COMPENSATION_FAILED: immediate Tier 1 page + admin repair API unlocked (IAM + MFA required)

9. Security Architecture (🔪 Device Binding Added)

Token & Device Lifecycle

Access token	RS256 JWT · 15-min TTL · contains user_id + scopes + device_id claim
Refresh token family	7-day TTL · Family-wide revocation on stolen token detection · Old token reused after rotation → entire family invalidated + forced re-auth
Device binding (NEW)	Mobile app generates keypair on device secure element · Public key registered in identity-service at enrolment · Every critical request includes X-Device-Signature header · fraud-service computes device_trust_score based on binding age and usage history
JWT validation	API Gateway: validates all requests · Services: re-validate signature via JWKS on high-risk endpoints (payment initiation, balance reads) · Defense in depth — single gateway failure does not compromise auth
Device loss / change	recovery-service handles re-enrolment · ID upload + video KYC required · Old device certificates revoked in identity-service

Service-to-Service Auth

AWS IAM roles	Each ECS task has a role granting only documented service-to-service paths. No admin IAM.
mTLS	Every service presents client certificate. ACM manages rotation. Invalid cert = rejected.
Zero-trust	No service trusts another based on network location, even within the same VPC.
support-service	Separate internal IdP + IAM role. No API Gateway route. Internal VPC only.

Audit Log Tiers

Tier 1 — Financial (7 years)	Every signed ledger entry, every saga state transition, every repair action with justification. S3 Object Lock WORM. FICA.
Tier 2 — Security (2 years)	Auth events, device binding events, token family revocations, admin API calls. WORM.
Tier 3 — Compliance (7 years, NEW)	PEP hits, AML flags, STR filings, sanctions matches. Separate compliance_audit_log. WORM. SARB/FSCA.
Tier 4 — Operational (90 days)	Health events, config changes, deployments, circuit breaker state changes. Mutable.

10. Observability & SLOs

Service Level Objectives

SLO 1 Payment Success Rate

99.5% · rolling 28 days

% of saga initiations reaching COMPLETED Excludes: fraud rejections, user cancellations, sanctions blocks, exhausted fallback (VOICE_FALLBACK_FAILED) Burn rate alert: page if >2% budget burns in 1 hour

SLO 2 API Latency

p99 < 300ms · rolling 7 days

wallet-service and identity-service endpoints only Excludes: payment initiation, health checks

SLO 3 Ledger Consistency

100% · every reconciliation run

SUM(signed_amount) = 0 on every 6-hour run Hard invariant — no error budget On failure: immediate page + payment suspension

SLO 4 Voice Verification Availability

99.9% · rolling 7 days

% of verifications returning a result within 35 seconds Fallback OTP delivery is a valid outcome — measures the auth pipeline, not just voice Excludes declared maintenance windows

Alert Tiers

Tier 1 — Page immediately

Ledger reconciliation failure · COMPENSATION_FAILED · Payment SLO burn >2%/hr · voice.spoof_detected >10/min · Any service >1% 5xx for >2min · Sanctions/PEP match on high-value account · Token family revocation spike RULE: every Tier 1 alert has a runbook URL in the alert body

Tier 2 — Business hours Slack

ML inference p99 >500ms · DLQ depth >100 · Voice fallback rate >5% · New device for high-value user · STR filing rate spike

Tier 3 — Ticket next sprint

Gradual latency trend · Fraud model score distribution shift · Outbox relay lag >5s · Certificate expiry <30 days · AML rule hit rate change

11. Implementation Phases

20 Weeks · 7 Phases · Exit gates are binary — open or closed

Build invariants first, features second. Exit gates block progression. No phase starts until the previous gate is passed without exception.

PHASE 1 · Ledger Core		Weeks 1–3
Week 1	signed_amount PostgreSQL schema: ledger_entries, account_balances, accounts. ledger-service append-only write path. SELECT FOR UPDATE. signed_amount CHECK. Reconciliation test SUM(signed_amount)=0 written before any application code.	
Week 2	Double-entry validation with signed amounts. account_balances updated in same transaction. Outbox table + polling relay stub. Unit tests: 100% coverage on all ledger logic. POST /repair stub (IAM gated).	
Week 3	LedgerEntryPosted to Kafka. CQRS read model in wallet-service. Integration test: 10 concurrent payments — overdraft impossible, SUM(signed_amount)=0.	
EXIT GATE	Reconciliation test SUM(signed_amount)=0 after 10,000 random ops including concurrency. Repair stub callable.	

PHASE 2 · Payment Saga Core		Weeks 4–6
Week 4	payment_sagas with all 18 states including 3 fallback states. idempotency_keys. Saga state machine with all steps stubbed. auth_policy field populated.	
Week 5	Full outbox: compensation + repair events. All payment.* events published. notification-service skeleton. Integration tests: idempotency, compensation flows.	
Week 6	COMPENSATION_FAILED → Tier 1 alert + admin repair API invoked in test. COMPENSATION_FAILED runbook written first. Voice fallback states wired (stub OTP). All five original reconciliation tests passing.	
EXIT GATE	All integration suites pass. COMPENSATION_FAILED fires alert AND repair API callable. Ledger balances on all outcomes.	

PHASE 3 · Fraud, Identity & Compliance

Weeks 7–9

Week 7	identity-service: JWT RS256, OAuth2, JWKS, token family revocation. Device public key registration. X-Device-Signature validation on critical endpoints. API Gateway JWT validation. Rate limiting.
Week 8	fraud-service: rules engine Layer 1 + Redis velocity checks. auth_policy output wired to saga. compliance-service: PEP/AML/sanctions (binary match). Pact contract tests for fraud.scored.
Week 9	fraud-service: ML scoring Layer 2. Shadow mode dual scoring. device_trust_score integrated into fraud features. PEP hit fires compliance.hit event and blocks payment. Device signature validated in integration tests.
EXIT GATE	PEP hit explicitly blocks payment. Device signature validated. ML model in shadow mode. Zero false positives on curated test set.

PHASE 4 · Voice + Biometrics & Fallback

Weeks 10–12

Week 10	voice-service FastAPI: pgvector schema + audio_fingerprint_hashes. Liveness detection (passive + active challenge). Enrollment: 3-sample average. Challenge phrase + 30-second TTL.
Week 11	Full verification pipeline: anti-spoof → liveness → transcript → embedding → confidence → threshold. voice.fallback_requested published on failure. Fallback flows wired: notification-service delivers OTP. VOICE_FALLBACK_PENDING state active.
Week 12	Tiered degradation by transaction value and auth_policy. Circuit breaker: voice down → OTP fallback automatically. Chaos Scenario 5: voice outage → OTP fallback completes payment. Spoof alert fires.
EXIT GATE	Voice failure gracefully routes to OTP fallback in staging. High-value requires both. Spoof detection alert fires. Degradation proven.

PHASE 5 · Admin, Support & Recovery ★

Weeks 13–15

Week 13	support-service: transaction search, account freeze, dispute intake, audit log browsing. Internal-only, IAM + internal IdP. Read-only replica of ledger. Linked to ledger-service POST /repair.
Week 14	recovery-service: ID upload + video KYC integration. Voice re-enrolment flow. Device certificate re-issue. recovery.completed event wired to identity-service and voice-service.
Week 15	Admin repair drill: SRE team performs mock COMPENSATION_FAILED repair via support-service → ledger-service /repair. Witnessed and logged. Recovery flow end-to-end tested. Internal UI basic dashboard.
EXIT GATE	Admin can repair COMPENSATION_FAILED via API. Recovery re-enrolment tested end-to-end. Repair drill witnessed and logged.

PHASE 6 · Observability & Disaster Recovery

Weeks 16–18

Week 16	OpenTelemetry all services. Kafka trace_id in headers. CloudWatch structured JSON mandatory fields. Four golden signals per service. Terraform full IaC. Three-tier VPC. ECS Fargate task definitions.
Week 17	SLO dashboards: all four with error budgets and burn rate alerts. Three-tier alert hierarchy. Runbooks for every Tier 1 alert. 6-hour reconciliation schedule + auto-suspend. mTLS certificates. S3 Object Lock WORM.
Week 18	GitHub Actions five-stage pipeline. Blue/green + canary. Manual approval gate. Cross-region RDS replica. First automated DR restore test: ledger DB + reconciliation. Monthly DR test schedule established.
EXIT GATE	All SLOs measurable and green for 48 hours. DR restore test passed with reconciliation. All Tier 1 runbooks linked.

PHASE 7 · Hardening & Launch

Weeks 19–20

Week 19	All five chaos scenarios in staging (AWS FIS + Toxiproxy). External penetration test executed. All Pact contract tests in place. OWASP ZAP clean in CI. No Critical CVEs in any container image.
Week 20	48-hour staging reconciliation run (signed_amount). Voice shadow mode 48-hour validation (false positive <0.1%). Voice OTP fallback: 100 test payments with voice degraded — all succeed. Performance test at 10x load. All 16 launch criteria gates signed off.
EXIT GATE	Zero Critical/High pen test findings. 48-hour reconciliation clean. Voice fallback 100/100. All 16 launch gates signed GO.

12. Testing Strategy (★ +3 New Suites)

Unit Tests	JUnit 5 + Mockito (Java) · pytest (Python) Coverage: 80% floor · 100% on signed ledger logic, saga transitions, idempotency Never mock: domain logic, state machine transitions, signed_amount validation
Contract Tests	Pact consumer-driven contracts for all Kafka event shapes Schema Registry BACKWARD compatibility check as CI gate on every PR
Integration Tests	Real PostgreSQL, real Kafka, real Redis — no in-memory substitutes Voice + fraud ML: test doubles with deterministic outputs 9 suites (6 original + 3 new)
Chaos Tests	5 scenarios using AWS FIS + Toxiproxy · Staging only Scenario 5 (voice outage): must prove OTP fallback completes payment
Reconciliation Tests	5 mandatory tests — all release gates SUM(signed_amount)=0 · Balance projection accuracy · Saga-ledger consistency Idempotency under Kafka replay · Point-in-time reconstruction
Penetration Test	External firm, pre-launch Scope includes: device binding bypass, voice replay, token family attacks, admin API abuse Release gate: zero Critical/High unresolved

All 9 Integration Test Suites

Suite 1: Happy path (voice passes) — Saga reaches COMPLETED. Signed ledger entries correct. SUM(signed_amount)=0. payment.completed published.

Suite 2: Idempotency — Same payment twice. Cached response returned. Exactly one set of ledger entries.

Suite 3: Compensation — Failure at LEDGER_COMMITTING. Saga reaches COMPENSATED. Escrow returned. Net signed_amount=0.

Suite 4: Concurrent race — 10 simultaneous payments, total exceeds balance. No overdraft. Ledger balanced after all.

Suite 5: Voice timeout → OTP fallback success — Voice times out. Saga → VOICE_FALLBACK_PENDING. OTP delivered and verified. Payment completes.

Suite 6: Fraud block — Score ≥ 0.90 . Saga → FRAUD_REJECTED. Zero ledger entries. fraud.scored event correct.

Suite 7 ★: Voice fallback failure (all factors exhausted) — Voice fails + OTP invalid. Saga reaches VOICE_FALLBACK_FAILED. Zero funds moved. No compensation needed.

Suite 8 ★: Admin repair drill — Trigger COMPENSATION_FAILED. Invoke admin repair API (IAM+MFA). Corrective signed entry posted. Ledger balances. Audit log updated with justification.

Suite 9 ★: Device theft — token family revocation — Stolen refresh token reused after rotation. Entire token family revoked. User forced to re-authenticate. identity.token_family_revoked event published.

13. Infrastructure & Deployment

Network Architecture

Public subnets	AWS API Gateway · NAT Gateway · Nothing else is public
Private app subnets	All ECS Fargate tasks · support-service on isolated segment (internal IdP only) · Explicit security group rules
Private data subnets	All RDS clusters · ElastiCache Redis · MSK Kafka · Inbound from app subnets only
Security groups	Explicit: payment-service → ledger-service port 8080 · All → MSK 9092 · All → RDS 5432 · No open CIDR ranges

CI/CD Pipeline — Five Stages

Stage 1 Build & Test	Unit tests · Contract tests · SpotBugs/Bandit · OWASP Dependency Check · trufflehog (PR blocked on secret detection)
Stage 2 Container Build	Docker build · ECR CVE scan · Immutable tag = git commit SHA · 'latest' never deployed
Stage 3 Integration Tests	Docker Compose full stack · All 9 integration suites · Signed ledger reconciliation test
Stage 4 Deploy to Staging	ECS rolling deploy 50% min healthy · Smoke tests · SLO burn rate check
Stage 5 Deploy to Production	Manual approval (senior engineer) · Blue/green · 5% canary 10min · Auto-rollback · Post-deploy reconciliation run

Disaster Recovery

Ledger RTO / RPO	RTO 15 minutes · RPO 0 · RDS Multi-AZ + cross-region synchronous replica
Payment RTO / RPO	RTO 30 minutes · RPO 5 minutes
Voice / Fraud / Support RTO	RTO 60 minutes · RPO 1 hour
Backup strategy	RDS automated 35-day · Daily snapshots 7-year for ledger_db · PITR all clusters
DR test cadence	Monthly automated restore — ledger_db + SUM(signed_amount)=0 assertion · Failure = Tier 1 incident

14. Critical Invariants

These must never be violated — not in hotfixes, not in emergencies

SIGNED LEDGER ZERO-SUM

SELECT SUM(signed_amount) FROM ledger_entries must equal 0 at all times. Negative for debits, positive for credits. Checked every 6 hours. Automatic payment suspension if it fails. No exceptions.

APPEND-ONLY LEDGER

No UPDATE or DELETE on ledger_entries, ever. Corrections via POST /repair — a new signed compensating entry with mandatory justification. Audit trail must be complete.

SINGLE WRITE PATH

Only ledger-service writes to ledger_db. Enforced at credentials level. No other service has a connection string to ledger_db.

VOICE NEVER BLOCKS A LEGITIMATE PAYMENT

Voice failure → VOICE_FALLBACK_PENDING → OTP/PIN. Voice service outage → circuit breaker → OTP fallback automatically. VOICE_FALLBACK_FAILED means all factors failed — not just voice.

SAME-TRANSACTION OUTBOX

Outbox row in same PostgreSQL transaction as ledger write. Transaction rollback = outbox row does not exist.

COMPENSATION_FAILED IS HUMAN-IN-THE-LOOP

Immediate Tier 1 page. Admin repair API (IAM+MFA) unlocked. Repair action logged with justification. Drill completed before launch.

DEVICE BINDING IS ENFORCED

X-Device-Signature validated by identity-service on all critical endpoints. Missing or invalid signature = 401. No bypass in production.

SHADOW MODE BEFORE MODEL PROMOTION

No ML model promoted without 48-hour shadow run on real traffic. False positive rate < 0.1% required. Human review gate mandatory.

MONTHLY DR RESTORE TEST

Ledger restore + SUM(signed_amount)=0 assertion must pass monthly. Untested backup is not a backup.

15. Launch Criteria (★ 16 Gates — 5 New in v2.0)

System goes to production when every item is marked GO

01	Reconciliation	48-hour run: SUM(signed_amount)=0 in staging — zero discrepancies. All 5 reconciliation suites pass.	■ GO ■ NO-GO
02	Chaos Testing	All 5 scenarios pass. Voice outage → OTP fallback completes payment. Circuit breakers proven.	■ GO ■ NO-GO
03	DR Restore + Repair	DR restore test passed. Repair API tested in DR scenario.	■ GO ■ NO-GO
04	Penetration Test	Zero Critical or High findings unresolved. Device binding, token family, admin API in scope.	■ GO ■ NO-GO
05	SLOs Green	All 4 SLOs measurable and green in staging for 48 hours.	■ GO ■ NO-GO
06	Runbooks Written	All Tier 1 runbooks linked in alert bodies. COMPENSATION_FAILED repair guide signed off.	■ GO ■ NO-GO
07	Contract Tests	All Pact contracts in place. Schema Registry compatibility on all topics.	■ GO ■ NO-GO
08	Security Scanning	OWASP ZAP clean. No Critical CVEs. No secrets in code, env, or images.	■ GO ■ NO-GO
09	Migration Complete	Historical migration done. SUM(signed_amount)=0 before and after. Legacy tables read-only.	■ GO ■ NO-GO
10	Voice Shadow Mode	48-hour shadow run. False positive rate < 0.1%. Spoof alert tested.	■ GO ■ NO-GO
11	Performance	10x expected load. p99 latency within SLO. Signed reconciliation holds under load.	■ GO ■ NO-GO
12	★ Voice OTP Fallback	100 test payments completed via OTP fallback with voice intentionally degraded. 100/100 success.	■ GO ■ NO-GO
13	★ Admin Repair Drill	SRE team performs mock COMPENSATION_FAILED repair via admin API. Witnessed and logged. Justification in audit trail.	■ GO ■ NO-GO
14	★ Device Binding	All mobile integration tests pass with X-Device-Signature required. Token family revocation proven.	■ GO ■ NO-GO
15	★ Compliance Audit	SARB/FSCA PEP/AML rules validated by external compliance consultant. STR workflow tested.	■ GO ■ NO-GO

16	Documentation	All runbooks complete. ADR signed off. On-call rotation and escalation path documented.	■ GO ■ NO-GO
----	---------------	---	--------------

THE LEDGER IS THE SYSTEM. Keep the signed reconciliation test green and you know the system is honest. Let it fail, and nothing else matters.

THE CUSTOMER IS THE REASON. If voice locks out a legitimate user, we have failed — regardless of ledger correctness.